

NovaPay Solutions Ltd.

ISO/IEC 27001:2022 GRC Assessment and ISMS Implementation Portfolio Report

Prepared by	Bola
Organisation	NovaPay Solutions Ltd. (fictional case study)
Industry	FinTech / Digital Payments
Framework	ISO/IEC 27001:2022
Purpose	Cybersecurity GRC portfolio project

Portfolio disclaimer: NovaPay Solutions Ltd. is a fictional organisation adapted from the supplied PayNest capstone case study. No real employer, customer or production data is used.

This report consolidates the project into one end-to-end GRC workflow: business context -> scope -> assets -> gaps -> risks -> treatment -> controls -> evidence -> PDCA improvement.

Contents

1. Executive Summary
 2. Project Basis and Approach
 3. Organisational Context
 4. ISMS Scope
 5. Information Asset Inventory
 6. ISO/IEC 27001 Gap Analysis
 7. Risk Assessment Methodology
 8. Risk Register Summary
 9. Risk Treatment Plan
 10. Selected Annex A Controls and SoA Approach
 11. Information Security Objectives
 12. Six-Month PDCA Roadmap
 13. Evidence and Assurance Approach
 14. Key Recommendations
 15. Conclusion
- Appendix A. Traceability
- Appendix B. Assumptions and Evidence Limitations
- References and Source Basis

1. Executive Summary

NovaPay Solutions Ltd. is a growing Ireland-based fintech company providing digital payment services to individuals and small businesses across Ireland and selected European markets. The business handles customer information, transaction data, employee information, financial records, application/source code and cloud-based systems. As the organisation scales, management wants a more formal, repeatable and evidence-driven approach to information security.

The confirmed issues include an undefined ISMS scope, incomplete policies, no formal asset inventory, inconsistent risk assessments, no formal control-selection process or Statement of Applicability, irregular awareness training, and inconsistent third-party security checks.

The assessment converts the case-study findings into a practical ISMS design. The core recommendation is to move from reactive security decisions to a defined, risk-based and evidence-driven management system. This means that important security decisions should be repeatable, assigned to accountable owners, supported by evidence and reviewed through an ongoing improvement cycle.

The risk assessment identifies 12 priority scenarios across access control, phishing, third parties, asset management, application security, cloud security, vulnerability management, monitoring, incident response, service availability, compliance and privileged access. Where the case study does not provide evidence that an existing control is operating effectively, the current residual risk is conservatively kept equal to the inherent risk rather than assuming a reduction.

A six-month PDCA roadmap is proposed to establish governance and scope, complete risk and documentation work, implement priority controls, measure effectiveness, perform internal audit, address findings and conduct management review. External certification should only be considered after NovaPay can demonstrate that the ISMS is operating effectively.

2. Project Basis and Approach

The original capstone assigns the role of Junior GRC Consultant and asks for an ISMS scope, gap analysis, risk assessment, Annex A control recommendations and a PDCA improvement plan. For this GitHub portfolio version, the fictional company name has been changed from PayNest Technologies to NovaPay Solutions Ltd., and the location has been adapted to Ireland. The underlying business model and confirmed security gaps remain the same.

Stage	Question	Output
Understand	What does the business do, what information does it depend on, and who has security expectations?	Business context and interested parties
Scope	Which people, processes, information, technology and third parties are governed by the ISMS?	ISMS scope statement
Identify	What assets need protection and what is currently missing?	Asset inventory and gap analysis
Assess	What can go wrong, how likely is it, and what would the impact be?	Risk register
Treat	How will unacceptable risks be reduced, avoided, shared or accepted?	Risk treatment plan
Control	Which controls address the identified risks?	Control recommendations and selected-control SoA
Assure	What evidence shows that controls are implemented and effective?	Evidence tracker and control testing
Improve	How will the ISMS be implemented, tested and improved?	PDCA roadmap

Evidence principle

Confirmed facts are separated from assumptions. A missing policy, report or screenshot is treated as an evidence gap unless the case study explicitly states that the control does not exist. This avoids overstating weaknesses or effectiveness.

3. Organisational Context

NovaPay's core service is digital payment processing for individuals and small businesses. Information-security objectives therefore need to preserve the confidentiality of customer and employee information, the integrity of transaction and financial records, and the availability of payment services and supporting cloud systems.

Business Function	Critical Information / Activity	Potential Business Impact
Payment Operations	Transaction data and payment processing	Failed or manipulated transactions, revenue loss, customer impact
Customer Operations	Customer records and account support	Privacy incident, account compromise, loss of trust
Software Development	Source code and application releases	Security defects, unauthorized changes, service compromise
IT / Cloud Operations	Cloud platforms, endpoints and supporting technology	Service disruption, unauthorized access, data exposure
Administration / People	Employee data and access lifecycle	Insider risk, excessive access, privacy exposure
Finance / Management	Financial records and oversight	Fraud exposure, reporting error, reputational impact

Interested Parties

Customers expect secure and reliable payment services. Employees expect secure handling of workforce information. Senior management requires controlled risk exposure and measurable performance. Suppliers and payment partners require clearly defined responsibilities. Regulators and authorities expect compliance with applicable obligations.

4. ISMS Scope

The NovaPay Solutions Ltd. ISMS covers the people, processes, information assets, applications, cloud infrastructure, supporting technologies and third-party services involved in the development, operation, administration and support of NovaPay's digital payment services for individuals and small businesses.

Boundary	In Scope
People	Management, IT, Software Development, Operations, Administration and personnel with access to in-scope systems or information.
Processes	Payment operations, customer support, software development, access management, incident management, supplier management, asset management, backup and continuity.
Information	Customer information, transaction data, employee information, financial records, source code, logs and operational records.
Technology	Payment application, cloud-based systems, repositories/development tooling where used, databases, endpoints, networks and security tooling.
Third Parties	Cloud, technology, payment and other suppliers that store, process, transmit or support in-scope information and services.
Locations	Corporate/operational locations and approved remote-working environments used for in-scope activities.

5. Information Asset Inventory

The case explicitly states that NovaPay has no formal information asset inventory. The starter register below establishes an initial view of critical assets, proposed ownership, classification and business importance. Owners remain placeholders until management validates accountability.

ID	Asset	Type	Proposed Owner	Class.	Criticality
A01	Customer Information	Information	Customer Operations	Confidential	Critical
A02	Transaction Data	Information	Payment Operations	Confidential	Critical
A03	Payment Application	Application	IT / Product	Restricted	Critical
A04	Application Source Code	Information	Software Development	Restricted	High
A05	Cloud Infrastructure	Technology	IT / Cloud Operations	Restricted	Critical
A06	Customer Database	Technology / Data Store	IT / Operations	Restricted	Critical
A07	Employee Information	Information	Administration / HR	Confidential	High
A08	Financial Records	Information	Finance / Management	Confidential	High
A09	Identity and Access Platform	Technology	IT / Security	Restricted	Critical
A10	Security Logs and Audit Records	Information	IT / Security	Confidential	High
A11	Supplier and Contract Records	Information	Management / Procurement	Confidential	Medium
A12	Employee Endpoints	Technology	IT	Internal	High

The full editable asset register is provided separately in the GitHub portfolio workbook.

6. ISO/IEC 27001 Gap Analysis

The gap analysis includes confirmed weaknesses from the case study and two additional evidence areas that should be checked before certification readiness. This distinction is important: lack of evidence is not treated as automatic proof of control failure.

ID	Evidence	Gap	ISO Reference	Priority
G01	Confirmed	No clearly defined ISMS scope	Clause 4.3	Critical
G02	Confirmed	Security policies are incomplete	Clause 5.2; A.5.1	High
G03	Confirmed	No formal information asset inventory	A.5.9; A.5.12	High
G04	Confirmed	Risk assessments are inconsistent	Clause 6.1.2	Critical
G05	Confirmed	Security controls have not been formally selected	Clause 6.1.3	Critical
G06	Confirmed	No Statement of Applicability (SoA)	Clause 6.1.3	Critical
G07	Confirmed	Security awareness training is irregular	A.6.3	High
G08	Confirmed	Third-party security checks are inconsistent	A.5.19-A.5.23	High
G09	Confirmed from case scenario	Security risk decisions are largely reactive	Clauses 6.1, 8.1; A.5.24-A.5.27	High
G10	Evidence not provided	Formal information security objectives and measures are not evidenced	Clause 6.2; 9.1	High
G11	Evidence not provided	Internal audit and management-review evidence is not provided	Clauses 9.2 and 9.3	Critical

Key pattern

Most confirmed gaps are governance and assurance problems rather than a statement that NovaPay has no technical security. The organisation needs formal scope, ownership, risk criteria, policy structure, supplier governance, control selection and evidence collection so that management can make consistent risk decisions.

7. Risk Assessment Methodology

Risk Score = Likelihood x Impact, using a five-point qualitative scale.

Score	Likelihood	Impact
1	Rare	Insignificant
2	Unlikely	Minor
3	Possible	Moderate
4	Likely	Major
5	Almost Certain	Severe
Score	Rating	Response
1-4	Low	Routine management and monitoring
5-9	Moderate	Treat where practical and monitor
10-14	High	Formal treatment plan and accountable owner
15-25	Critical	Priority treatment and senior-management visibility

Inherent risk is assessed before controls. Current residual risk considers controls that can be evidenced as operating. Target residual risk represents the desired level after planned treatment is implemented and tested.

Portfolio control-effectiveness rule: where operating effectiveness is not evidenced, current residual risk is not reduced.

8. Risk Register Summary

ID	Risk Scenario	Inherent	Treatment	Target
R01	Weak or inconsistently governed access could allow unauthorized access to customer or transaction information, causing confidentiality breach, fraud exposure and loss of trust.	4 x 5 = 20	Mitigate	2 x 5 = 10
R02	Irregular security awareness may enable phishing or social engineering, resulting in credential compromise and unauthorized system access.	4 x 4 = 16	Mitigate	2 x 4 = 8
R03	Inconsistent supplier security checks may allow a vulnerable or poorly controlled third party to compromise NovaPay information or services.	3 x 5 = 15	Mitigate / Share	2 x 5 = 10
R04	Without a formal asset inventory, critical assets may be unmanaged, unowned or incorrectly protected, increasing the likelihood of loss or exposure.	3 x 4 = 12	Mitigate	2 x 4 = 8
R05	Inadequate secure-development governance may introduce exploitable defects or unauthorized code changes into the payment service.	3 x 5 = 15	Mitigate	2 x 5 = 10
R06	Unmanaged cloud configuration or access could expose services/data or cause disruption.	3 x 4 = 12	Mitigate	2 x 4 = 8
R07	Technical vulnerabilities may remain exploitable if identification and remediation are not governed consistently.	3 x 4 = 12	Mitigate	2 x 4 = 8
R08	Insufficient logging or monitoring could delay detection of account misuse, attacks or transaction-related anomalies.	3 x 4 = 12	Mitigate	2 x 4 = 8
R09	Reactive security decision-making may lead to inconsistent incident assessment, escalation, containment and lessons learned.	3 x 4 = 12	Mitigate	2 x 4 = 8
R10	A technology, supplier or cyber disruption could make digital payment services unavailable and materially affect customers and operations.	3 x 5 = 15	Mitigate / Share	2 x 5 = 10

ID	Risk Scenario	Inherent	Treatment	Target
R11	Failure to identify and meet applicable privacy, legal or contractual requirements could cause regulatory, contractual and reputational harm.	3 x 5 = 15	Mitigate	2 x 5 = 10
R12	Excessive privileged or repository access could allow unauthorized disclosure or alteration of source code and production-related configurations.	2 x 5 = 10	Mitigate	1 x 5 = 5

Current residual position

Because the case study does not provide verified operating-effectiveness evidence for the relevant controls, the portfolio register keeps the current residual score equal to the inherent score. This is intentionally conservative. Once control evidence is collected and tested, the residual score can be reassessed.

9. Risk Treatment Plan

Risk	Planned Treatment Action	Owner	Target
R01	Implement role-based access, identity lifecycle controls, secure authentication/MFA, periodic access reviews and security logging.	IT/Security + Business Owners	10
R02	Formalize awareness training, phishing education, event reporting and strong authentication.	GRC/HR + IT	8
R03	Tier suppliers by risk; perform due diligence; include security clauses; monitor critical suppliers and cloud services.	GRC/Procurement/IT	10
R04	Create asset inventory; assign owners; classify information; define acceptable-use and lifecycle requirements.	IT/GRC + Asset Owners	8
R05	Establish secure SDLC, application security requirements, secure coding, security testing and controlled changes.	Engineering + Security	10
R06	Establish cloud security responsibilities, configuration baselines, access controls and periodic review.	Cloud/IT + Security	8
R07	Implement vulnerability scanning, risk-based remediation SLAs, exception handling and tracking.	IT/Security	8
R08	Define logging standards, centralize security-relevant logs, alert on priority events and review monitoring effectiveness.	Security/IT	8
R09	Document incident roles, severity criteria, response procedures, evidence handling and lessons learned; run a tabletop exercise.	Security/GRC/Management	8
R10	Complete business impact analysis; define recovery objectives; test backups, continuity and supplier dependencies.	Operations/IT/Management	10
R11	Maintain obligations register; implement privacy/PII controls; retain evidence and periodically review compliance.	GRC/Legal/Management	10
R12	Restrict privileged and source-code access; review entitlements; protect repositories; log administrative actions.	Engineering/IT/Security	5

Residual risk acceptance

The target residual score is not an automatic approval. After implementation and control testing, the risk owner and management should confirm whether the remaining risk is within NovaPay's approved appetite/tolerance and document any formal acceptance.

10. Selected Annex A Controls and SoA Approach

The case study asks for Annex A recommendations and a Statement of Applicability. This portfolio uses a selected-control SoA to show the logic between gaps, risks and controls. For formal certification work, management should complete its control determination against the full Annex A reference set and document inclusion/exclusion rationale.

Control	Title	Implementation Status
A.5.1	Policies for information security	Partially Implemented
A.5.2	Information security roles and responsibilities	To Be Assessed / Implemented
A.5.9	Inventory of information and other associated assets	Not Implemented
A.5.12	Classification of information	To Be Assessed / Implemented
A.5.15	Access control	To Be Assessed / Implemented
A.5.16	Identity management	To Be Assessed / Implemented
A.5.17	Authentication information	To Be Assessed / Implemented
A.5.18	Access rights	To Be Assessed / Implemented

Control	Title	Implementation Status
A.5.19	Information security in supplier relationships	Partially Implemented
A.5.20	Addressing information security within supplier agreements	Partially Implemented
A.5.22	Monitoring, review and change management of supplier services	Partially Implemented
A.5.23	Information security for use of cloud services	To Be Assessed / Implemented
A.5.24	Information security incident management planning and preparation	To Be Assessed / Implemented
A.5.26	Response to information security incidents	To Be Assessed / Implemented
A.5.30	ICT readiness for business continuity	To Be Assessed / Implemented
A.5.31	Legal, statutory, regulatory and contractual requirements	To Be Assessed / Implemented
A.5.34	Privacy and protection of PII	To Be Assessed / Implemented
A.6.3	Information security awareness, education and training	Partially Implemented
A.6.8	Information security event reporting	To Be Assessed / Implemented
A.8.5	Secure authentication	To Be Assessed / Implemented
A.8.8	Management of technical vulnerabilities	To Be Assessed / Implemented
A.8.15	Logging	To Be Assessed / Implemented
A.8.16	Monitoring activities	To Be Assessed / Implemented
A.8.20	Network security	To Be Assessed / Implemented
A.8.24	Use of cryptography	To Be Assessed / Implemented
A.8.25	Secure development life cycle	To Be Assessed / Implemented
A.8.28	Secure coding	To Be Assessed / Implemented
A.8.29	Security testing in development and acceptance	To Be Assessed / Implemented
A.8.32	Change management	To Be Assessed / Implemented

The full editable SoA workbook also records justification, case evidence, gap links and risk links.

11. Information Security Objectives

ID	Objective	Measure / Target	Timeframe	Owner
OBJ-01	Asset Management	100% of in-scope critical assets recorded and assigned an owner.	Within 60 days	IT/GRC
OBJ-02	Security Awareness	100% active personnel complete required training; new starters within 30 days.	Within 90 days, then ongoing	GRC/HR
OBJ-03	Access Governance	100% critical-system access reviews completed quarterly; leaver access removed within approved SLA.	Quarterly	IT/Security
OBJ-04	Supplier Security	100% critical suppliers assessed before onboarding and at defined intervals.	Within 120 days, then ongoing	GRC/Procurement
OBJ-05	Vulnerability Management	Critical vulnerabilities remediated within approved SLA or covered by documented exception/compensating control.	Within 120 days, then monthly	IT/Security
OBJ-06	Incident Readiness	Incident response plan tested at least annually; high-severity exercise findings tracked to closure.	Within 6 months, then annually	Security/Management

12. Six-Month PDCA Roadmap

Phase	Focus	Key Deliverable
Plan - Month 1	Context, scope, governance, asset inventory and risk criteria	Approved scope, roles, asset register and risk method
Plan / Do - Month 2	Risk register, policies and priority treatment design	Approved risks, policy framework and action owners
Do - Months 2-4	Implement access, supplier, cloud, vulnerability, monitoring, secure-development, awareness and continuity controls	Operating control evidence
Check - Months 3-5	Metrics, control testing and internal audit	Metrics, test results and audit findings
Act - Months 5-6	Corrective action and management review	Closed findings, management review and readiness decision

The roadmap is a readiness plan, not a certification guarantee. Certification should follow evidence that the management system is operating effectively.

13. Evidence and Assurance Approach

A GRC assessment should be able to show why a control conclusion was reached. For that reason, the portfolio includes an evidence tracker covering scope approval, policies, asset inventory, risk records, SoA, awareness, supplier due diligence, access reviews, incident readiness, vulnerability management, monitoring, secure development, continuity, internal audit and management review.

Evidence should be reviewed for relevance, completeness, timeliness and operating effectiveness. For example, a written access-control policy shows design intent, but a completed access review with approved removals provides stronger evidence that the control is operating.

14. Key Recommendations

- Approve the ISMS scope and governance structure before expanding documentation.
- Complete the asset inventory and assign accountable owners to critical information and technology assets.
- Standardise risk assessment criteria and require documented treatment or acceptance for High and Critical risks.
- Prioritise identity/access governance, supplier assurance, secure development, technical vulnerability management, monitoring, incident response and business continuity.

- Build a controlled policy set that maps to real operating processes and evidence rather than creating documents only for audit.
- Use the evidence tracker to confirm that planned controls are actually implemented and effective before reducing residual risk.
- Set measurable security objectives and provide management with periodic risk and control-performance reporting.
- Perform internal audit and management review before deciding whether the organisation is ready to engage a certification body.

15. Conclusion

NovaPay's rapid growth has created a mismatch between business dependence on information and the maturity of security governance. The organisation is not starting from zero, but several important practices are incomplete, inconsistent or not evidenced. The recommended response is a repeatable ISMS that connects assets, risks, controls, accountable owners, evidence and continual improvement.

This portfolio project therefore treats ISO/IEC 27001 as a management system rather than a checklist. The documents, spreadsheets and roadmap are designed to support practical risk decisions and make assurance evidence visible.

Appendix A. Traceability

Gap	Primary Risk Link	Requirement / Control Link	Roadmap Action
G01 No defined scope	R04, R11	Clause 4.3	Plan: scope and governance
G02 Incomplete policies	R01-R12	A.5.1, A.5.2	Do: policy framework
G03 No asset inventory	R04	A.5.9, A.5.12	Plan: asset inventory
G04 Inconsistent risk assessment	All risks	Clause 6.1.2	Plan: risk methodology
G05 Controls not formally selected	All treated risks	Clause 6.1.3	Do: treatment/control mapping
G06 No SoA	All treated risks	Clause 6.1.3	Do: approve SoA
G07 Irregular awareness	R02, R09	A.6.3, A.6.8, A.8.5	Do: recurring training
G08 Inconsistent supplier checks	R03, R06, R10, R11	A.5.19-A.5.23	Do: supplier governance
G09 Reactive security management	R08-R10	A.5.24-A.5.30; A.8.15-A.8.16	Plan/Do/Check
G10 Objectives/measurement not evidenced	R07, R08, R11	Clause 6.2; 9.1	Check: metrics and control testing
G11 Audit/review not evidenced	Residual risk across ISMS	Clauses 9.2 and 9.3	Check/Act: audit and management review

Appendix B. Assumptions and Evidence Limitations

Type	Statement
Portfolio adaptation	NovaPay (renamed from PayNest for the portfolio) is a fictional Ireland-based fintech scenario serving individuals and small businesses in Ireland and selected European markets.
Confirmed from case	The scenario handles customer information, transaction data, employee information, financial records, application/source code and cloud-based systems.
Confirmed from case	The supplied gaps include undefined ISMS scope, incomplete policies, no formal asset inventory, inconsistent risk assessments, no formally selected controls, no SoA, irregular awareness training and inconsistent third-party checks.
Assumption	Specific application names, cloud provider, database technology, network design, source-code platform, CI/CD tooling and endpoint/security products are not provided.
Assumption	Proposed control owners are role-based placeholders and must be validated in a real organisation.
Assumption	Risk scores are educational estimates for the portfolio, not quantitative values derived from production incident or loss data.
Evidence limitation	Except where the case explicitly describes a control, implementation/effectiveness is not assumed. Missing evidence is marked for assessment.
Scope limitation	The portfolio scenario places NovaPay in Ireland; applicable Irish/EU legal, regulatory and contractual obligations should be validated and recorded separately.
ISO content note	Control references are portfolio mappings. An authorised copy of ISO/IEC 27001:2022 should be used for formal certification work.

References and Source Basis

Primary case source: 10Alytics GRC C26-06, Compliance Framework Capstone Project - Implementing ISO/IEC 27001 for a Growing Startup, supplied by the user as PayNest_Capstone_Project.pdf.

ISO/IEC 27001:2022 official standard information: <https://www.iso.org/standard/27001>

ISO/IEC JTC 1/SC 27 Auditing Practices Group guidance was used as background for the relationship between risk treatment, Annex A and the Statement of Applicability.

Portfolio note: NovaPay Solutions Ltd. is fictional. No real employer, customer or production information is included.